

Spot the Vulnerability

A group activity for Module 7: IoT security.

Time: ~20 minutes. No coding, no Wokwi. Just reading and talking.

How it works: Your trainer splits the room into groups of 2–3 and gives each group 2–3 of the snippets below. For each snippet, talk about three questions: **What's wrong? What's the worst that could realistically happen? How would you fix it?** You have about 8 minutes. Then each group reads out its snippet and answer, in one sentence each.

Snippet 1 — the device's own code

```
const char* WIFI_SSID = "HomeNetwork";
const char* WIFI_PASSWORD = "Summer2024!";
...
// this file is committed to a public GitHub repository
```

Discuss: What's wrong, and what could someone do with this?

Snippet 2 — a smart camera's login page

```
Username: admin
Password: admin
(unchanged since the camera was installed 3 years ago)
```

Discuss: How common do you think this is in the real world? What's the realistic worst case?

Snippet 3 — sending data to the cloud

```
Device sends sensor readings to:
http://api.example.com/update?reading=23.5
(plain http, not https)
```

Discuss: Who else, besides the intended server, can see this data?

Snippet 4 — the messaging layer

MQTT topic used by 10,000 deployed smart door locks:
locks/status

Any device (or person) that connects to the broker can publish to
"locks/status" and every lock listens and obeys.

Discuss: What is missing here that Module 4's MQTT lesson didn't mention was required in a real product?

Snippet 5 — firmware updates

The device checks for new firmware once a week, downloads it over
plain HTTP, and installs it immediately with no signature check.

Discuss: If an attacker could intercept this download, what could they do?

Wrap-up

Think about the devices you own: a router, a camera, a smart plug. Have you seen any of these five mistakes in a real product? To go further, the [OWASP IoT Top 10](#) is the full checklist these five examples come from.